Studio Nx

Backend(FastAPI/Python) 31 — set_refresh_cookie() · clear_refresh_cookie()

2026-10-07

Backend(FastAPI/Python) 31 — `set_refresh_cookie()` · `clear_refresh_cookie()`

항목	내용
파일	`studionx/backend/app/api/v1/auth.py`
작업	P1-05 로그인 — 리프레시 쿠키 · PRD 01 FR-105 · FR-109
작성	Claude (AI) · 2026-10-07 · 사용자 검토
이전 · 다음	30 `get_active_user()` · 32 `POST /auth/login`

1. 하는 일

리프레시 토큰(27)을 브라우저 **쿠키**에 심고(`set`), 로그아웃할 때 지운다(`clear`). 응답 헤더 `Set-Cookie` 한 줄을 만든다.

호출	응답 헤더 `Set-Cookie`
`set_refresh_cookie(res, token, remember=True)`	`snx_refresh=eyJ…; HttpOnly; Max-Age=259200; Path=/api/v1/auth; SameSite=lax`
`set_refresh_cookie(res, token, remember=False)`	`snx_refresh=eyJ…; HttpOnly; Path=/api/v1/auth; SameSite=lax`
`clear_refresh_cookie(res)`	`snx_refresh=""; expires=(지금); HttpOnly; Max-Age=0; Path=/api/v1/auth; SameSite=lax`

쿠키 속성	값	뜻
`HttpOnly`	켬	**JS 가 읽을 수 없음** (`document.cookie` 에 안 보임). 스크립트 공격(XSS)이 훔쳐 가지 못함
`Path=/api/v1/auth`		`/api/v1/auth/…` 요청에만 실림. 다른 API · 페이지 요청에는 안 실림
`SameSite=lax`		다른 사이트가 몰래 보낸 `POST` 에는 안 실림 (CSRF 대비)
`Max-Age`	259200초(3일) 또는 없음	없으면 **세션 쿠키** — 브라우저를 닫으면 사라짐
`Secure`	배포(`APP_ENV=prod`)에서만	HTTPS 로만 보냄. 개발(`http://localhost`)에서 켜면 쿠키가 아예 안 실려서 끔

2. 언제 쓰나

쓰는 곳	함수	화면
32 `POST /auth/login`	`set_refresh_cookie(…, remember=data.remember)`	로그인 모달 — **Keep me signed in** 체크 여부
34 `POST /auth/logout`	`clear_refresh_cookie()`	헤더 **Sign Out** (JS 08)

Keep me signed in	브라우저를 닫았다 다시 열면
체크	3일 동안 쿠키가 남아 있음 → `api.js` 가 재발급 → 로그인된 채로

Keep me signed in	브라우저를 닫았다 다시 열면
체크 안 함	쿠키가 사라짐 → 재발급 실패 → 로그인 화면

3. 코드

import (파일 맨 위)

```
from typing import Annotated

from fastapi import APIRouter, Cookie, Query, Response, status
from pydantic import EmailStr

from app.api.deps import Db
from app.core.config import get_settings
from app.schemas.auth import (
    AvailabilityResponse,
    LoginRequest,
    Nickname,
    SignupRequest,
    SignupResponse,
    TokenResponse,
)
from app.schemas.common import ErrorResponse
from app.services import auth_service
```

`auth.py` 맨 위의 import 이다. **`from app.core.config import get_settings` 를 이번에 추가했다.** 이 함수들은 `Response` · `get_settings` 를 쓴다.

함수

```
REFRESH_COOKIE = "snx_refresh"
REFRESH_COOKIE_PATH = "/api/v1/auth"


def set_refresh_cookie(response: Response, token: str, remember: bool) -> None:
    settings = get_settings()
    if remember:
        max_age = settings.jwt_refresh_days * 24 * 60 * 60
    else:
        max_age = None
    response.set_cookie(
        key=REFRESH_COOKIE,
        value=token,
        path=REFRESH_COOKIE_PATH,
        httponly=True,
        samesite="lax",
        secure=settings.app_env == "prod",
        max_age=max_age,
    )


def clear_refresh_cookie(response: Response) -> None:
    response.delete_cookie(
        REFRESH_COOKIE,
```

```
        path=REFRESH_COOKIE_PATH,
        httponly=True,
        samesite="lax",
        secure=get_settings().app_env == "prod",
    )
```

문법 풀이

import 문법	뜻
`from app.core.config import get_settings`	`.env` 를 읽은 설정 (05 와 같음)

식	뜻
`response: Response`	라우터가 받은 응답 객체. 여기에 쿠키를 붙이면 응답 헤더로 나감
`response.set_cookie(key=…, value=…, …)`	`Set-Cookie` 헤더 한 줄을 만듦
`max_age=None`	`Max-Age` 를 아예 쓰지 않음 → 세션 쿠키
`settings.app_env == "prod"`	배포 환경이면 `True`
`response.delete_cookie(…)`	빈 값 + `Max-Age=0` 인 같은 이름의 쿠키를 보내 브라우저가 지우게 함
`-> None`	돌려주는 값 없음 — `response` 를 바꾸는 것이 일

4. 흐름

심기: 수명을 정한다(체크면 3일, 아니면 없음) → 속성을 붙여 `Set-Cookie` 를 만든다. **지우기:** 같은 이름 · 같은 경로로 "지금 만료" 쿠키를 보낸다.

5. 왜 이렇게

선택	이유
쿠키에 담음 (응답 본문 아님)	본문으로 주면 JS 가 어딘가에 저장해야 한다. `HttpOnly` 쿠키는 JS 가 손댈 수 없고, 브라우저가 알아서 보낸다
경로를 `/api/v1/auth` 로 좁힘	3일짜리 토큰이 모든 요청에 실려 다니지 않는다. 재발급 · 로그아웃할 때만 서버에 간다
체크 안 하면 세션 쿠키	공용 컴퓨터에서 브라우저를 닫으면 로그인이 풀린다 (FR-109)
`Secure` 는 배포에서만	개발 서버는 `http://` 라 `Secure` 쿠키가 실리지 않는다. 배포(HTTPS)에서는 반드시 켠다
지울 때도 같은 속성	브라우저는 이름 · 경로가 같아야 같은 쿠키로 보고 지운다. 템플릿은 경로만 맞췄지만, 속성까지 같게 해 두면 브라우저마다 다르게 처리할 걱정이 없다

6. 시험 (`tests/test_auth_cookies.py`, 새로 만듦 · 5개)

시험	확인한 것
체크	`snx_refresh=TOKEN`, `Max-Age=259200`, `Path=/api/v1/auth`, `HttpOnly`, `SameSite=lax`
체크 안 함	`Max-Age` · `expires` 없음 (세션 쿠키), `HttpOnly`

시험	확인한 것
`Secure` (2개)	설정을 `dev` 로 바꾸면 없음, `prod` 로 바꾸면 있음
지우기	빈 값, `Max-Age=0`, 같은 경로

전체 시험 218개 통과, `ruff` 검사 통과.